

MiniCISO Staff Service Catalog v5

Status: Current consolidated catalog for the public miniCISO overlay

Version: v5 Date: 2026-07-10

1. Executive Summary

O catálogo v5 consolida o estado atual do MiniCISO Staff como um overlay público e reproduzível para Hermes Agent, com foco em:

- coordenação central por chief-of-staff;
- SMEs especializados para análise técnica;
- security-qa como quality gate obrigatório;
- disciplina de evidência em três camadas;
- gate pré-submissão orientado por KAG para findings externos;
- decisão explícita G0 / RESEARCH / NO-G0 antes de qualquer report externo.

O avanço mais importante desta versão é metodológico: o sistema deixa de aceitar como finding válido um comportamento que apenas demonstra uma primitiva técnica sem impacto qualificável provado.

Estado público refletido neste catálogo

Este catálogo descreve o estado público atual do repositório miniCISO.

Ele contém 9 perfis publicados:

1. chief-of-staff
2. security-threat-modeling
3. security-architecture
4. security-code-review
5. security-appsec-assessment
6. security-offensive-security
7. security-compliance-mapper
8. security-recon-attack-surface-strategist
9. security-qa

Guardrails universais

- Sem remediação automática.
- Todo relatório final exige QA.
- Trabalho ofensivo exige autorização explícita, escopo, limites e critérios de parada.
- Findings externos não entram em drafting sem decisão G0.
- Evidência deve separar configuração declarada, runtime efetivo e comportamento validado quando aplicável.

2. O que muda na v5

A v5 herda a base metodológica da v4 e adiciona uma camada de controle mais rígida para findings externos, especialmente em BBP/VDP.

Principais mudanças

2.1. Gate KAG de validação pré-submissão

Nova regra oficial:

- nenhum draft externo começa antes da decisão G0;
- RESEARCH gera plano de validação de impacto, não submissão;
- NO-G0 bloqueia submissão e registra lição aprendida.

2.2. Separação formal entre primitiva e finding

Passa a ser obrigatório tratar como relações não equivalentes:

- primitiva técnica $\neq$ vulnerabilidade;
- comportamento observado $\neq$ impacto;
- capacidade potencial $\neq$ exploração demonstrada;
- acesso possível $\neq$ acesso comprovado;
- texto bom $\neq$ finding válido.

2.3. Adversarial QA

O QA deixa de ser apenas revisão de forma e passa a executar uma tentativa explícita de rejeição metodológica do finding, buscando:

- exclusão de programa;
- falta de impacto;
- ausência de quebra de trust boundary;
- hipótese apresentada como fato;
- severidade inflada;
- insuficiência probatória.

2.4. Impact Validator

O fluxo operacional passa a reconhecer explicitamente uma função intermediária entre descoberta e report drafting:

- transformar primitivas em hipóteses de impacto verificáveis e autorizadas; ou
- concluir que a primitiva não sustenta finding.

2.5. Artefato obrigatório de decisão

Todo finding externo passa a exigir um artefato com:

- regra/exclusão aplicável;
- impacto exigido;
- impacto demonstrado;
- força da evidência por claim;
- inferências proibidas;
- argumento mais forte de rejeição;
- checklist final para G0.

3. Modelo operacional do Staff

Fluxo principal

Usuário → MiniCISO → SME Especializado → Security QA → MiniCISO → Usuário

Função do coordenador

O chief-of-staff é responsável por:

- triagem inicial;
- decomposição do problema;
- escolha do SME correto;
- consolidação da resposta final;
- enforcement de QA;
- controle de escopo, risco e output.

Resultado esperado do sistema

O MiniCISO não é apenas um catálogo de personas. Ele funciona como uma equipe com:

- coordenação central;
- especialização por domínio;
- quality gate obrigatório;
- disciplina de evidência;
- formato consistente de saída.

4. Evidência, qualidade e risco

Modelo de evidência em três camadas

Toda conclusão deve, quando aplicável, separar:

1. Configuração declarada
arquivos, IaC, dashboards, documentação, intenção declarada.
2. Runtime / configuração efetiva
estado realmente carregado/aplicado pelo sistema.
3. Comportamento validado
teste controlado ou observação direta do efeito.

Regra de decisão

- Não concluir segurança apenas por configuração declarada.
- Quando houver conflito, runtime e comportamento prevalecem para avaliação de risco.
- Se runtime/comportamento não foram validados, reduzir Confidence Level.

Divergência de Configuração

Quando declarado, runtime e comportamento não batem, isso vira um achado próprio:

Classificação obrigatória: Divergência de Configuração

Campos esperados:

- controle afetado;
- estado declarado;
- estado runtime/efetivo;
- comportamento observado;
- impacto plausível;
- hipóteses de causa;
- validação adicional necessária;
- recomendação;
- owner sugerido;
- severidade e confidence.

5. Gate KAG para findings externos

Objetivo

Provar impacto qualificável ou bloquear submissão.

Pergunta correta

O sistema não deve começar perguntando:

Como transformar esta evidência em um bom report?

Deve começar perguntando:

Esta evidência sobreviveria à triagem como finding qualificável neste programa?

Estrutura mínima de decisão

O gate trabalha com quatro conjuntos de conhecimento:

1. Scope Graph
2. Vulnerability Graph
3. Evidence Graph
4. Decision Graph

Gates obrigatórios

Gate 1 — Scope Qualification

- a classe está no escopo?
- existe exclusão explícita?
- o programa exige impacto adicional?
- a evidência atual satisfaz esse requisito?
- o teste necessário é autorizado?

Gate 2 — Feature versus Vulnerability

- o comportamento viola uma trust boundary?
- ou só executa a função esperada do produto?

Gate 3 — Impact Closure A frase precisa fechar sem linguagem especulativa:

Por causa deste comportamento, um atacante pode [ação concreta], causando [consequência observável], algo que não seria possível por meio da funcionalidade normalmente autorizada.

Gate 4 — Evidence Sufficiency Cada claim deve ser classificado como:

- DIRECT
- SUPPORTED_INFERENCE
- SPECULATIVE
- UNSUPPORTED

Gate 5 — Adversarial QA O QA tenta rejeitar o finding antes de lapidar o texto.

Decisões permitidas

- G0
- RESEARCH
- NO-G0

Regra dura

- Se demonstrated = false, não existe G0.
- Se a evidência cai em exclusão explícita sem exceção provada, a submissão deve ser bloqueada.
- Mais prova da mesma primitiva não substitui ausência de impacto.

6. Perfis publicados e quando usar

6.1. chief-of-staff

Quando acionar

- coordenação geral;
- triagem de demanda;
- síntese final;
- roteamento entre SMEs;
- priorização e próximos passos.

Outcomes típicos

- briefing executivo;
- plano de ação;
- consolidação inter-SME;
- decisão operacional.

Entrada ideal

- objetivo;
- escopo;
- contexto;
- restrições;

- artefatos disponíveis.

6.2. security-threat-modeling

Quando acionar

- ativos, atores, trust boundaries, abuse cases, fluxos sensíveis.

Outcomes típicos

- threat model;
- cenários priorizados;
- backlog defensivo.

Entrada ideal

- diagrama/fluxo;
- ativos sensíveis;
- atores;
- objetivo da modelagem.

6.3. security-architecture

Quando acionar

- SSH, firewall, cloud, rede, systemd, gateways, exposição de serviços, segmentação, runtime divergente.

Outcomes típicos

- architecture review;
- tradeoffs;
- recomendações priorizadas;
- plano seguro de correção.

Entrada ideal

- desenho atual/alvo;
- configs declaradas;
- saídas runtime;
- testes observados;
- constraints.

6.4. security-code-review

Quando acionar

- revisão manual de repo, diff, scripts, auth, secrets, injection, lógica sensível.

Outcomes típicos

- findings por arquivo/linha;
- correção sugerida;
- guidance de testes.

Entrada ideal

- path ou diff;
- linguagem;
- foco de risco;
- permissão de execução de testes.

6.5. security-appsec-assessment

Quando acionar

- API, authn/authz, sessão, SAST/DAST/SCA, SBOM, manifests, containers, IaC.

Outcomes típicos

- assessment AppSec;
- falso positivo vs finding real;
- priorização;
- backlog técnico.

Entrada ideal

- scanner outputs;
- SARIF;
- SBOM;
- manifests;
- repositório;
- escopo da análise.

6.6. security-offensive-security

Quando acionar

- validação ofensiva autorizada;
- raciocínio adversarial seguro;
- PoCs controladas;
- interpretação de exploitabilidade.

Outcomes típicos

- plano de teste;
- evidência segura;
- critérios de parada;
- avaliação de impacto técnico.

Entrada ideal

- autorização explícita;
- alvo;
- limites;
- janela;
- regras de parada.

6.7. security-compliance-mapper

Quando acionar

- mapear achados para LGPD, GDPR, ISO 27001, SOC2, CIS, NIST e afins.

Outcomes típicos

- gap matrix;
- mapping;
- readiness roadmap.

Entrada ideal

- framework alvo;
- políticas/processos;
- achados técnicos;
- evidências;
- escopo.

6.8. security-recon-attack-surface-strategist

Quando acionar

- recon autorizado de baixo ruído;
- mapeamento e triagem de superfícies;
- priorização de hipóteses;
- ordem segura de validação.

Outcomes típicos

- surface map;
- hipóteses priorizadas;
- próximos gates;
- backlog de investigação.

Entrada ideal

- família de alvos;
- policy/restrições;
- orçamento de requests;
- sinais já observados.

Limite importante

Recon não é finding. O output precisa passar por AppSec/OffSec/Architecture e depois por QA antes de virar conclusão final.

6.9. security-qa

Quando acionar

- toda entrega final;
- addendum;
- mudança de severidade;
- validação de evidência;
- revisão de overclaim.

Outcomes típicos

- aprovado;
- aprovado com ressalvas;
- reprovado;
- correções obrigatórias.

Entrada ideal

- draft;
- evidências;
- escopo;
- público-alvo;
- critérios MiniCISO.

7. Notas sobre capacidades transversais

Além dos 9 perfis públicos, o overlay atual já documenta algumas práticas transversais que influenciam a operação, mesmo sem aparecerem como perfis separados.

7.1. Governança de findings externos

O estado público atual já documenta, via operating model + KAG gate + templates, uma disciplina de governança para findings externos com foco em:

- policy-first;
- scope qualification;
- authorization-aware validation;
- evidence minimization;
- bloqueio de submissão quando não há impacto qualificável demonstrado.

7.2. Lições aprendidas como requisito de processo

O overlay público já exige o registro de lição aprendida quando um candidate finding cai em N0-G0.

Na prática, isso reforça principalmente:

- falhas metodológicas;
- overclaim a partir de primitiva técnica;
- casos em que faltou prova de impacto;
- repetições de inferências proibidas.

7.3. Supply-chain como área de análise, não como perfil público separado

O estado público atual suporta análise de supply-chain principalmente dentro de security-appsec-assessment e da documentação de dependências/configuração.

Este catálogo não assume, no overlay público atual, a existência de um perfil separado de supply-chain nem de um componente público chamado Watchman.

8. Template universal de intake

O input de alta qualidade para o MiniCISO deve conter, no mínimo:

Objective

- o que precisa ser decidido ou produzido

Scope

- sistemas, repositórios, assets
- in scope
- out of scope

Context

- background
- constraints
- business/security priority

Program and qualification context

- nome do programa
- plataforma
- URL da policy
- source das regras
- exclusões explícitas
- impacto exigido para a classe
- métodos permitidos
- métodos proibidos
- se callback/OOB é permitido
- estágio atual: intake | validation | report-drafting

Artifacts provided

- arquivos
- links
- logs / screenshots / reports

Restrictions

- read-only?
- external testing authorized?
- sensitive data constraints?

Desired output

- tipo de saída
- profundidade
- prazo

QA requirement

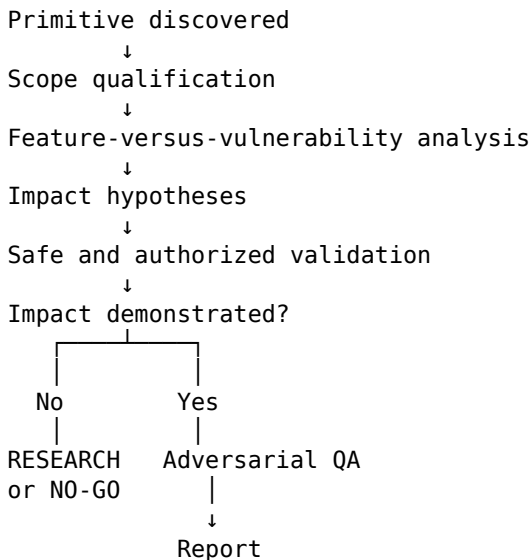
- saída final passa por security-qa

9. Workflow recomendado

9.1. Fluxo geral

Intake → Triagem → SME → Draft técnico → Security QA → Síntese final → Follow-up

9.2. Fluxo para findings externos



9.3. Critério de saída

- GO → pode começar drafting externo
- RESEARCH → gera plano de validação de impacto
- NO-GO → bloqueia submissão e registra aprendizado

10. Prompts copy-ready

10.1. Threat modeling

Faça uma threat model de [sistema/fluxo]. Contexto: [objetivo]. Artefatos: [diagrama/fluxo]. Dados sensíveis: [lista]. Atores: [lista]. Quero riscos priorizados, recomendações, assumptions, confidence level, residual risk e next steps. Passe pelo Security QA.

10.2. Architecture review

Revise esta arquitetura/controle. Stack: [stack]. Declarado: [configs]. Runtime: [outputs]. Comportamento: [testes]. Constraints: [prazo/custo/risco]. Quero recomendações priorizadas, divergências, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

10.3. Secure code review

Revise segurança do código em [path/diff]. Foco: [categorias]. Pode executar testes locais: [sim/não]. Quero findings, falso positivo se aplicável, remediação proposta,

assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

10.4. AppSec assessment

Avalie os findings de AppSec deste projeto. Artefatos: [scanner outputs], [SARIF], [SBOM], [repo]. Objetivo: [reduzir risco/validar findings/priorizar backlog]. Quero confirmados, falso positivos, priorização, remediação proposta, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

10.5. Recon / attack surface

Faça recon autorizado e de baixo ruído para [família de alvos]. Constraints: [policy/rate limits]. Sinais já observados: [lista]. Quero mapa de superfícies, hipóteses priorizadas e próximos gates seguros. Não trate recon como finding final. Passe pelo fluxo correto até QA.

10.6. QA adversarial para finding externo

Valide este candidate finding com gate KAG orientado por impacto. Primeiro tente rejeitar o finding pelos motivos mais fortes de triagem. Só aprove G0 se houver trust boundary quebrada, impacto diretamente demonstrado e evidência suficiente. Caso contrário, devolva RESEARCH ou N0-G0 com rationale e próximas ações seguras.

11. Critérios de qualidade para a versão atual

Um output MiniCISO de alta qualidade deve:

- ser ancorado em evidência real;
- distinguir fato, hipótese e lacuna;
- explicitar assumptions;
- calibrar confidence;
- declarar residual risk;
- propor próximos passos concretos;
- passar por security-qa quando final.

Para findings externos, adicionalmente deve:

- respeitar escopo/autorização;
- não overclaimar a partir de primitiva técnica;
- não usar linguagem especulativa como base de submissão;
- provar impacto qualificável ou bloquear a submissão.

12. Conclusão

A v5 marca a maturidade do MiniCISO Staff como um sistema orientado a decisão, não apenas a produção de texto.

Os pontos centrais desta versão são:

- coordenação clara;
- QA obrigatório;

- disciplina de evidência;
- tratamento explícito de divergência;
- recon como insumo, não como finding;
- gate KAG para findings externos;
- decisão G0 / RESEARCH / NO-G0 antes de drafting.

Em termos práticos, a v5 reduz a chance de:

- aprovar relatório bem escrito sem impacto demonstrado;
- confundir comportamento esperado com vulnerabilidade;
- transformar primitiva em finding só por familiaridade com a classe;
- submeter casos que deveriam ter sido travados em QA.